Compagnia Theta

Progetto di infrastruttura di rete e sicurezza informatica

Technical Report

CyberSniffer

Indice

1. Introduzione Generale 1
2. SEZIONE PER IL MANAGEMENT NON TECNICO 1
2.1. Executive Summary 1
2.2. Obiettivi Aziendali 2
2.3. Benefici Attesi 3
2.4. Rischi principali mitigati 3
2.5. Componenti principali del progetto 4
2.6. Impatto sull·organizzazione 5
2.7. Costi e preventivo 5
2.8. Conclusione per il management 10
3. SEZIONE TECNICA PER IL REPARTO IT 10
3.1. Requisiti tecnici di progetto 10
3.2. Architettura logica proposta 11
3.3. Segmentazione della rete 12
3.4. Piano di indirizzamento IP 14
3.5. Apparati di rete 15
3.6. Regole firewall iniziali 16
3.7. Web server e DMZ 20
3.8. HTTP Tester 22
3.9. Scansione porte 25
3.10. Sniffer di rete 27
3.11. Sicurezza e Hardening (misure previste e raccomandate) 31
3.12. Piano di test: test eseguiti e test raccomandati 32
3.13. Criteri di accettazione 34

Il presente documento descrive la proposta progettuale per la realizzazione dell'infrastruttura di rete della Compagnia Theta. Il report è suddiviso in due sezioni principali: una prima parte destinata al management aziendale, con linguaggio orientato a benefici, rischi e impatto operativo, e una seconda parte tecnica destinata al reparto IT, contenente architettura di rete, configurazioni logiche, sicurezza, test e raccomandazioni operative.

1. INTRODUZIONE GENERALE

Scopo del report è presentare una proposta di infrastruttura per la Compagnia Theta. Descriveremo le scelte progettuali sia dal punto di vista aziendale che tecnico, documentando sicurezza, test e risultati attesi, e in più forniremo raccomandazioni finali su future implementazioni.

La Compagnia necessita di una rete aziendale strutturata, sicura e scalabile. L'edificio è composto da 6 piani, ogni piano prevede 20 computer, per un totale di 120 postazioni.

L'obiettivo finale è realizzare una rete interna efficiente che garantisca accesso controllato a Internet e protegga i servizi aziendali tramite firewall, DMZ, IDS/IPS e segmentazione logica. Valideremo infine il progetto con test di rete e sicurezza.

2. SEZIONE PER IL MANAGEMENT NON TECNICO

Questa parte del report è pensata per il management aziendale della Compagnia Theta. L'obiettivo è spiegare il progetto di rete in modo chiaro, senza entrare eccessivamente nei dettagli tecnici. Le configurazioni specifiche, come subnetting, regole firewall, VLAN, scansione porte e test HTTP, saranno invece approfondite nella sezione dedicata al reparto IT. Il progetto nasce dalla necessità di realizzare un'infrastruttura di rete per un edificio composto da 6 piani, con 20 computer per piano, per un totale di 120 postazioni aziendali, più componenti di sicurezza e servizi centralizzati come firewall, NAS, web server e IDS/IPS.

2.1. Executive Summary

La Compagnia Theta necessita di una rete aziendale stabile, sicura e organizzata, in grado di supportare le attività quotidiane dei dipendenti e proteggere le risorse informatiche aziendali. Il progetto prevede la realizzazione di un'infrastruttura di rete distribuita su 6 piani, con collegamento di 120 computer aziendali, suddivisi in modo ordinato e gestibile.

La soluzione proposta comprende switch dedicati per ogni piano, un router centrale per collegare le diverse aree della rete, un firewall perimetrale per proteggere il collegamento verso Internet, un NAS per la gestione centralizzata dei dati, un web server collocato in una zona separata e controllata e sistemi IDS/IPS per rilevare e prevenire attività sospette.
Dal punto di vista aziendale, il progetto mira a garantire maggiore continuità operativa, migliore protezione dei dati, controllo degli accessi, riduzione dei rischi informatici, maggiore efficienza nella gestione dell'infrastruttura IT.

La rete sarà progettata secondo un principio fondamentale: separare le aree critiche dell'azienda, così da evitare che un eventuale problema su un servizio esposto a Internet possa compromettere direttamente tutta la rete interna.

2.2. Obiettivi Aziendali

Nell'ottica di garantire una rete stabile per tutte le postazioni aziendali, la rete dovrà permettere ai 120 computer previsti di comunicare in modo efficiente. Ogni piano dell'edificio dovrà dunque avere una connessione affidabile e l'infrastruttura dovrà ridurre interruzioni, rallentamenti e problemi di connettività.

Per garantire la protezione dei dati e dei sistemi aziendali, essendo la sicurezza informatica obiettivo centrale del nostro progetto, i dati aziendali dovranno essere protetti da accessi non autorizzati, errori di configurazione e minacce provenienti dall'esterno. Il NAS dovrà consentire una gestione centralizzata e più controllata dei file aziendali.

Per separare la rete interna dai servizi esposti a Internet, il web server dovrà essere posizionato in una zona separata, detta DMZ. Questa separazione consente di ridurre il rischio che un attacco al web server possa raggiungere direttamente i computer interni dell'azienda.

Per garantire un completo controllo da parte del reparto IT, la rete dovrà essere facilmente monitorabile e gestibile, così da permettere al reparto IT di poter individuare rapidamente anomalie, problemi di traffico e tentativi di intrusione. L'uso di sistemi IDS/IPS permetterà di migliorare la capacità di rilevamento e risposta.

L'infrastruttura sarà scalabile, nel senso che la rete sarà progettata non solo per esigenze attuali, ma anche per eventuali espansioni future. Siccome la Compagnia potrebbe in futuro aumentare il numero di dipendenti, dispositivi o servizi, una progettazione ordinata consentirà di espandere la rete senza doverla riprogettare completamente.

Una rete non strutturata può causare disservizi, vulnerabilità e difficoltà di manutenzione. Il progetto ha l'obiettivo di ridurre questi rischi attraverso una struttura chiara, documentata e sicura, riducendo di conseguenza il rischio operativo.

2.3. Benefici Attesi

Nel contesto di garantire una maggiore efficienza operativa, i dipendenti potranno lavorare su una rete più stabile e organizzata. La distribuzione dei dispositivi per piano, infatti, renderà più semplice la gestione tecnica. Una rete ben progettata, inoltre, riduce tempi di inattività e problemi ricorrenti.

Per garantire una migliore sicurezza complessiva, il firewall controllerà il traffico tra Internet e la rete aziendale, i sistemi IDS/IPS aiuteranno a identificare attività sospette e la separazione tra rete interna e DMZ ridurrà l'esposizione dei sistemi critici.

Per assicurare una centralizzazione dei dati, il NAS permetterà di raccogliere e gestire i file aziendali in un punto centralizzato. Questo faciliterà backup, controllo degli accessi e organizzazione dei dati. La centralizzazione riduce il rischio di dispersione delle informazioni su singoli computer.

Il reparto IT potrà monitorare più facilmente dispositivi, traffico e servizi. La documentazione della rete renderà più semplici manutenzione, aggiornamenti e risoluzione dei problemi.

Investire in una rete sicura ridurrà inoltre i rischi economici legati a incidenti informatici. Un attacco informatico o malfunzionamento della rete può causare interruzioni del lavoro, perdita di dati e costi di ripristino. Una buona progettazione iniziale riduce anche i costi futuri di correzione o ristrutturazione.

L'azienda disporrà di una rete più vicina agli standard professionali. La presenza di firewall, DMZ, NAS e IDS/IPS aumenterà il livello di maturità informatica dell'organizzazione, garantendo una maggiore professionalità dell'ambiente IT.

2.4. Rischi principali mitigati

Per evitare accessi non autorizzati alla rete interna, il firewall e la segmentazione della rete impediranno ad utenti esterni o dispositivi compromessi di accedere alla rete aziendale.

L'utilizzo di una DMZ consentirà di isolare il web server dal resto della rete, impedendo l'esposizione diretta dei sistemi aziendali a Internet.

Il NAS consentirà una gestione più ordinata, con possibilità di backup e controllo dei permessi, impedendo di fatto la compromissione dei dati aziendali.

La separazione della rete in aree distinte limiterà la diffusione laterale di un attacco, limitando la possibilità di propagazione.

Gli IDS/IPS permetteranno di rilevare comportamenti sospetti e generare avvisi, impedendo a molti attacchi o anomalie di passare inosservati.

I test di scansione porte permetteranno di individuare porte aperte o servizi non necessari che possono diventare punti di ingresso per attacchi.

Il test dei verbi HTTP servirà a verificare quali metodi sono attivi e se devono essere disabilitati, poiché alcuni metodi HTTP, se abilitati senza necessità, possono introdurre rischi.

2.5. Componenti principali del progetto

Ogni piano sarà collegato tramite uno switch dedicato. Lo switch consentirà ai computer dello stesso piano di comunicare con la rete aziendale. Questa scelta semplifica la gestione e rende più ordinata la distribuzione dei collegamenti.

Il router centrale collegherà tra loro diverse parti della rete. Permetterà la comunicazione tra i piani, i server e gli altri servizi aziendali. È uno degli elementi principali per l'organizzazione del traffico interno.

Il firewall protegge la rete aziendale rispetto a Internet, filtrando il traffico in ingresso e in uscita. Permetterà solo le comunicazioni autorizzate e bloccherà quelle potenzialmente pericolose.

Il web server rappresenterà il servizio accessibile dall'esterno. Nel progetto sarà simulato tramite una macchina vulnerabile utilizzata a scopo didattico. Sarà collocato in una zona separata dalla rete interna, per motivi di sicurezza.

La DMZ, zona intermedia tra Internet e la rete interna aziendale, servirà a ospitare servizi che devono essere raggiungibili dall'esterno, come il web server. Proteggerà la rete interna nel caso in cui il server pubblico venga compromesso.

Il NAS, sistema di archiviazione centralizzata, permetterà ai dipendenti autorizzati di accedere ai file aziendali, facilitando la gestione dei dati, dei backup e dei permessi di accesso.

Gli IDS/IPS, sistemi dedicati al rilevamento e alla prevenzione delle intrusioni, monitoreranno il traffico di rete alla ricerca di attività sospette. Aiuteranno il reparto IT a intervenire rapidamente in caso di minaccia.

Gli Script di test serviranno a validare il livello di sicurezza della rete progettata. Saranno realizzati a tal proposito strumenti in Python per verificare i metodi HTTP attivi sul web server ed eseguire una scansione delle porte sui dispositivi di rete.

2.6. Impatto sull'organizzazione

Per quanto riguarda l'impatto sul management, il progetto aumenta il livello di sicurezza e affidabilità dell'azienda, riducendo i rischi legati ad interruzioni operative e incidenti informatici fornendo una base infrastrutturale più adatta alla crescita futura.

Per il reparto IT la rete sarà più semplice da monitorare, documentare e gestire in quanto gli apparati saranno organizzati in modo logico e sarà dunque più facile individuare problemi, isolare guasti e applicare regole di sicurezza.

Per i dipendenti i miglioramenti riscontrabili saranno una connessione più stabile, accesso a dati condivisi più ordinato e la separazione delle aree di rete ridurrà l'impatto di eventuali problemi tecnici.

Per quanto riguarda la sicurezza aziendale, la presenza di firewall, DMZ e IDS/IPS migliorerà la protezione complessiva in quanto la rete sarà meno esposta ad attacchi provenienti da Internet e gli eventi sospetti potranno essere rilevati ed analizzati.

Nel contesto di garantire continuità operativa, infine, va ribadito che una rete progettata correttamente riduce il rischio di blocchi generalizzati. La separazione tra piani, servizi interni e servizi pubblici consente una gestione più efficace dei problemi. In tal modo, eventuali incidenti potranno essere contenuti più facilmente.

2.7. Costi e preventivo

Il preventivo di spesa descrive i costi stimati per la realizzazione dell'infrastruttura di rete. Il preventivo distingue tra scenario base, con VLAN e protezione perimetrale e scenario completo, con aggiunta di un secondo firewall interno e rafforzamento della separazione tra DMZ, LAN e NAS.

Sintesi del Progetto

L'infrastruttura servirà un totale di **120 postazioni di lavoro**, integrate con servizi server in zona demilitarizzata (DMZ), storage di rete (NAS) e sistemi di rilevamento delle intrusioni (IDS/IPS). La segmentazione logica tramite VLAN sostituisce il modello a porte fisiche dedicate sul router, riducendo la complessità del cablaggio e aumentando la flessibilità nella gestione del traffico inter-piano.

Componente	Quantità / Dettaglio
Struttura fisica	6 piani, 20 computer per piano
Switch di piano (managed, 802.1Q)	6 -- uno per piano, uplink trunk verso il router
Router (VLAN-capable / sub-interfacce)	1 -- gestisce il routing inter-VLAN
Firewall perimetrale	1 -- filtra Internet DMZ (VLAN 100)
Firewall interno (opzionale)	1 -- filtra DMZ LAN (inter-VLAN)
Web Server (Metasploitable)	1 -- VLAN 100 (DMZ)
NAS	1 -- VLAN 110 (Storage isolato)
Nodi IDS/IPS	3 -- VLAN 120 (Security monitoring)
VLAN totali configurate	11 (VLAN 10–120 + VLAN 999 blackhole)

Figura 1 - Sintesi del progetto e componenti principali del preventivo.

Questa voce, mostrata in figura, comprende tutte le attività necessarie per installare, configurare e ottimizzare gli apparati di rete e sicurezza. Include anche la configurazione delle VLAN sugli switch managed e sul router centrale. Dal punto di vista del management questa fase è fondamentale perché permette di trasformare i singoli apparati fisici in una rete realmente funzionante, sicura e controllabile.

Attività di Configurazione	Costo (Euro)
Configurazione Firewall Perimetrale + Setup DMZ	€2.000
Implementazione 3× IDS/IPS (con SPAN per monitoraggio VLAN)	€2.000
Configurazione NAS e Permessi di Accesso	€600
Hardening dei Sistemi e Sicurezza Generale	€1.000

Figura 2 - Attività di configurazione software e sistemi.

Come da requisiti, verranno sviluppati tool personalizzati per il monitoraggio e il collaudo della sicurezza, mostrati in figura. Il Custom Port Scanner servirà a verificare quali porte risultano aperte o chiuse sui dispositivi analizzati. L'HTTP Tester servirà a controllare quali metodi HTTP risultano abilitati sul web server. Lo script dedicato a phpMyAdmin permetterà di testare i metodi disponibili su uno specifico percorso applicativo.

Sviluppo Strumenti di Testing (Python)

Come da requisiti, verranno sviluppati tool personalizzati per il monitoraggio e il collaudo della sicurezza. Gli strumenti esistenti sono compatibili con l'architettura VLAN in quanto operano a livello applicativo (L7) e non richiedono modifiche.

Sviluppo Software Custom	Costo (Euro)
Custom Port Scanner (Python)	€800
HTTP Tester & Verifier Verbi HTTP	€800
Script Verifica Metodi (phpMyAdmin Path)	€500
Totale Sviluppo Software	**€2.100**

Figura 3 - Sviluppo strumenti Python e costi previsti.

La manodopera rappresenta una delle componenti principali del preventivo, mostrato in figura, perché il progetto richiede competenze specialistiche in ambito networking, cybersecurity e sviluppo software. Le attività previste comprendono progettazione, configurazione, testing, debugging, verifica delle VLAN e produzione della documentazione finale. La variazione tra costo minimo e massimo dipende dal tempo effettivamente necessario per completare configurazioni, test e correzioni. Per il management, questo intervallo consente di considerare sia uno scenario ottimistico sia uno scenario più prudente, nel caso emergano complessità durante la fase di implementazione.

Manodopera e Servizi Professionali

Il costo del personale specializzato rappresenta la componente principale dell'investimento. Le ore sono state aggiornate per includere la configurazione, il testing e la verifica dell'infrastruttura VLAN.

Fase di Lavoro	Ore Previste
Progettazione Logica e Fisica della Rete (incl. schema VLAN)	20 - 30 h
Configurazione Infrastruttura, Sicurezza e VLAN	45 - 65 h
Testing, Debugging, Verifica VLAN e Reportistica Finale	25 - 35 h
Totale Ore	**90 - 130 h**
Voce	**Dettaglio**
Tariffa oraria	€80/ora
Ore minime (90h)	€7.200
Ore massime (130h)	€10.400
Totale Servizi Professionali	**€7.200 – €10.400**

Figura 4 - Stima della manodopera e dei servizi professionali.

Lo scenario base include configurazione software e sistemi, sviluppo degli strumenti di testing, manodopera e servizi professionali, segmentazione tramite VLAN, firewall

perimetrale, DMZ, NAS e IDS/IPS. Lo scenario base rappresenta la soluzione minima consigliata per realizzare una rete aziendale strutturata, segmentata e dotata dei principali controlli di sicurezza.

Riepilogo Finanziario

Voce	Minimo	Massimo
Configurazione Software e Sistemi	€6.800	€6.800
Sviluppo Strumenti di Testing (Python)	€2.100	€2.100
Manodopera e Servizi Professionali	€7.200	€10.400
TOTALE STIMATO	**€16.100**	**€19.300**

Tempi e Risorse

Tempi di realizzazione: 3-5 settimane dall'accettazione del preventivo

Figura 5 - Riepilogo finanziario dello scenario base.

Il tempo stimato per la realizzazione del progetto è di 3-5 settimane dall'accettazione del preventivo. Il team necessario è composto da 5 figure specializzate (Project Manager, Network Engineer, Cybersecurity Specialist, Software Developer/Python Developer, Technical Documentation e Testing Specialist). Questa composizione consente di coprire tutte le aree del progetto, ovvero progettazione della rete, configurazione degli apparati, implementazione della sicurezza, sviluppo degli script di test, validazione finale e produzione della documentazione.

Il preventivo prevede anche una configurazione opzionale più avanzata, basata su un'architettura a doppio firewall, mostrato in figura. In questo scenario il firewall esterno gestisce il traffico tra Internet e la DMZ, mentre il firewall interno protegge la LAN e il NAS dal traffico proveniente dalla DMZ. Le VLAN e le ACL aumentano il controllo tra le diverse aree della rete. Il NAS viene ulteriormente isolato nella VLAN dedicata e gli IDS/IPS vengono configurati per monitorare il traffico tramite porte SPAN. Questa opzione è consigliata se la Compagnia desidera un livello di sicurezza superiore. Il principale vantaggio è che, anche in caso di compromissione del web server nella DMZ, l'attaccante troverebbe un ulteriore livello di protezione prima di poter raggiungere la rete interna o il NAS.

Analisi dei Costi — Configurazione Opzionale

Voce di Costo	Dettaglio Tecnico	Costo (Euro)
Configurazione Doppio Firewall + Integrazione VLAN ACL	Setup architettura, regole DMZ (VLAN 100), ACL inter-VLAN su firewall interno.	€4.000
Setup e Tuning IDS/IPS (con SPAN multi-VLAN)	Configurazione di 3 nodi + porte SPAN per monitoraggio passivo su tutte le VLAN. Sessioni di tuning per eliminare falsi allarmi.	€2.500
Hardening NAS + Isolamento VLAN 110	Indurimento dei sistemi, permessi granulari e ACL specifiche per VLAN 110 (Storage).	€1.000
Configurazione VLAN (inclusa nella sezione base)	Voce già conteggiata nel totale base (€1.200 nella sezione 2A).	Incluso
Totale Stimato (Servizi Professionali Opzionali)		**€7.500**

Scenario	Totale Minimo	Totale Massimo

Figura c - Configurazione opzionale con doppio firewall.

Confrontando i due scenari, in figura, lo scenario base è più economico e copre le esigenze principali di connettività, segmentazione e sicurezza. Lo scenario completo richiede un investimento maggiore, ma offre protezione più robusta, soprattutto nella separazione tra DMZ, LAN e NAS. La differenza tra i due scenari è pari a 7500 euro, corrispondente ai servizi professionali opzionali necessari per rafforzare l'architettura con doppio firewall, tuning IDS/IPS e hardening avanzato del NAS.

Scenario	Totale Minimo	Totale Massimo
Base (con VLAN, senza doppio firewall)	€16.100	€19.300
Completo (con VLAN + doppio firewall)	€23.600	€26.800

Figura 7 - Confronto tra scenario base e scenario completo.

Per una soluzione equilibrata tra costo e sicurezza, lo scenario base da 16.100 a 19.300 euro rappresenta la proposta minima consigliata. Per una protezione più solida, soprattutto in presenza di servizi esposti verso Internet, è consigliabile valutare lo scenario completo da 23.600 a 26.800 euro. La scelta finale dipenderà dal livello di rischio che la Compagnia è disposta ad accettare. Se l'obiettivo principale è realizzare una rete funzionale, segmentata e protetta, lo scenario base è sufficiente. Se l'obiettivo è aumentare la resilienza contro attacchi provenienti dalla DMZ, lo scenario completo è preferibile. Dal punto di vista del management, lo scenario completo offre una maggiore tutela dell'infrastruttura critica e

riduce ulteriormente il rischio che un problema sul web server possa propagarsi verso la rete interna aziendale.

2.8. Conclusione per il management

Il progetto di rete per la Compagnia rappresenta un intervento strategico per migliorare sicurezza, efficienza e continuità operativa. La soluzione proposta risponde alle esigenze principali dell'azienda, ovvero collegare in modo ordinato 120 postazioni distribuite su 6 piani, proteggere la rete interna da minacce esterne, centralizzare l'accesso ai dati tramite NAS, monitorare il traffico con sistemi IDS/IPS e fornire al reparto IT una struttura più semplice da gestire.

Dal punto di vista del management, il valore del progetto non è solo tecnico, ma anche organizzativo, riducendo i rischi, migliorando la produttività, proteggendo le informazioni aziendali, preparando l'azienda a future espansioni e aumentando il livello generale di affidabilità dell'infrastruttura.

3. SEZIONE TECNICA PER IL REPARTO IT

3.1. Requisiti tecnici di progetto

Il progetto di rete per la Compagnia Theta è stato sviluppato con l'obiettivo di realizzare un'infrastruttura aziendale sicura, scalabile e funzionale alle esigenze operative dell'organizzazione. La rete è stata progettata per servire un edificio composto da 6 piani, ciascuno dotato di 20 postazioni di lavoro, per un totale di 120 computer aziendali.

Tra i componenti principali richiesti rientrano un firewall perimetrale, un NAS, un web server rappresentato da Metasploitable/DVWA e tre sistemi IDS/IPS. Il firewall protegge il collegamento tra rete aziendale e Internet, il NAS centralizza l'archiviazione dei dati, il web server viene collocato in DMZ e gli IDS/IPS sono previsti per il monitoraggio del traffico e la rilevazione di anomalie.

Il progetto comprende inoltre la realizzazione di strumenti Python per la verifica dei metodi HTTP e per la scansione delle porte. Tali strumenti permettono di produrre evidenze tecniche utili alla validazione dell'infrastruttura e alla formulazione delle raccomandazioni di sicurezza.

Nota di coerenza tra progetto e simulazione: il report distingue tra il modello progettuale completo, rappresentato nelle tabelle di indirizzamento e nella topologia generale, e la

simulazione pratica di laboratorio, utilizzata per verificare firewall, DMZ, connettività e strumenti Python. Nella simulazione alcuni indirizzi IP possono essere semplificati rispetto al piano IP definitivo; questa differenza viene indicata nelle sezioni interessate.

Dal punto di vista progettuale, i requisiti tecnici fondamentali sono:

• realizzazione di una rete aziendale distribuita su 6 piani;

• collegamento di 120 computer aziendali;

• utilizzo di switch dedicati per ciascun piano;

• collegamento degli switch a un router o apparato centrale di instradamento;

• protezione della rete tramite firewall perimetrale;

• collocazione del web server in DMZ;

• integrazione di un NAS per l'archiviazione centralizzata;

• previsione di 3 sistemi IDS/IPS;

• verifica dei metodi HTTP abilitati sul web server;

• sviluppo di uno scanner porte personalizzato in Python;

• redazione di una documentazione finale completa per reparto IT e management.

Nel complesso, la soluzione proposta combina connettività, segmentazione, sicurezza perimetrale, monitoraggio e testing, fornendo alla Compagnia Theta una rete organizzata, controllabile e più sicura rispetto a un'architettura non segmentata.

3.2. Architettura logica proposta

L'architettura logica proposta è stata progettata per garantire una comunicazione ordinata tra i piani dell'edificio, una separazione chiara tra le aree interne e i servizi esposti verso l'esterno, e un livello di sicurezza adeguato per l'intera infrastruttura.

La rete interna è organizzata secondo una struttura gerarchica: i sei switch di piano (dal Piano 0 al Piano 5) collegano le 20 postazioni previste per ciascun livello e convogliano il traffico verso un core switch di aggregazione. Dal core switch il traffico raggiunge il router centrale, che gestisce l'instradamento tra le reti interne e il collegamento verso il firewall perimetrale.

Il NAS è previsto nella rete interna, con indirizzo 192.168.0.100/24, in una posizione centrale e raggiungibile solo dai segmenti autorizzati. Non deve essere esposto direttamente verso Internet o verso la DMZ, poiché contiene dati aziendali e deve essere protetto tramite permessi, autenticazione e backup.

La rete esterna è gestita tramite firewall perimetrale, posizionato tra Internet e l'infrastruttura aziendale. Il firewall filtra il traffico in ingresso e in uscita, consentendo solo le comunicazioni autorizzate.

Il web server, simulato tramite Metasploitable/DVWA, viene collocato in DMZ. La DMZ rappresenta un'area intermedia tra Internet e la LAN interna, destinata ai servizi che devono essere raggiungibili dall'esterno. Il server in DMZ non deve avere accesso libero alla LAN.

Per il monitoraggio sono previsti tre sistemi IDS/IPS nella rete 192.168.100.0/24: uno dedicato al controllo del perimetro interno e due ulteriori sensori per il monitoraggio del traffico tra le zone principali. In assenza di screenshot di configurazione IDS/IPS, tali sistemi sono da considerarsi elementi del modello progettuale e non componenti completamente validate nella simulazione.

Questa architettura consente di ottenere una rete strutturata su più livelli: rete utenti, servizi interni, DMZ, apparati di sicurezza e monitoraggio. La soluzione garantisce equilibrio tra funzionalità, sicurezza, scalabilità e semplicità di gestione.

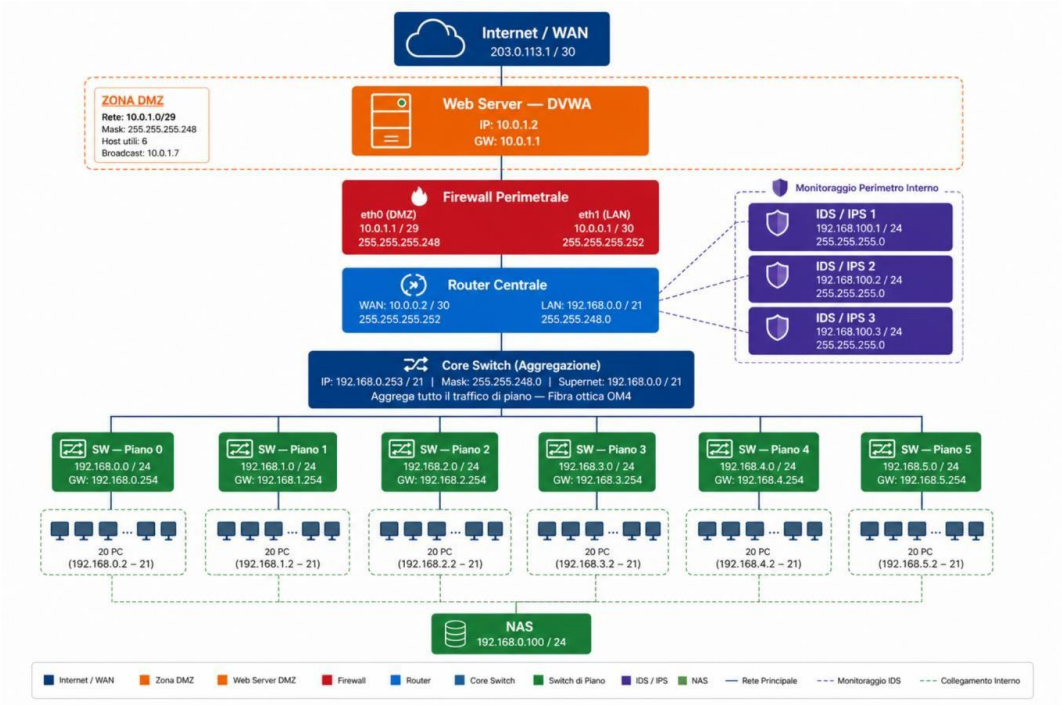

Figura 8 - Topologia logica definitiva della rete Theta.

3.3. Segmentazione della rete

La segmentazione della rete è stata progettata per separare logicamente le diverse aree dell'infrastruttura. L'obiettivo è evitare che tutti i dispositivi appartengano alla stessa rete,

riducendo il rischio che un problema su un singolo host possa propagarsi liberamente all'intera organizzazione.

Nel modello progettuale completo la segmentazione può essere realizzata tramite VLAN; nella rappresentazione attuale viene descritta soprattutto tramite zone e subnet. Per mantenere coerenza con gli screenshot presenti, la tabella va interpretata come segmentazione logica per zone/subnet, associabile a VLAN in fase di implementazione.

La segmentazione logica per zone e subnet è la seguente:

• WAN link: 10.0.0.0/30 - collegamento punto-punto tra firewall e router.

• DMZ: 10.0.1.0/29 - zona dedicata al web server Metasploitable/DVWA e all'interfaccia firewall DMZ.

• Piano 0/LAN: 192.168.0.0/24 - postazioni del piano 0 e NAS.

• Piano 1/LAN: 192.168.1.0/24 - postazioni del piano 1.

• Piano 2/LAN: 192.168.2.0/24 - postazioni del piano 2.

• Piano 3/LAN: 192.168.3.0/24 - postazioni del piano 3.

• Piano 4/LAN: 192.168.4.0/24 - postazioni del piano 4.

• Piano 5/LAN: 192.168.5.0/24 - postazioni del piano 5.

• Monitoraggio: 192.168.100.0/24 - rete dedicata ai tre IDS/IPS.

• Supernet LAN: 192.168.0.0/21 - riepilogo dell'indirizzamento interno dei piani.

La VLAN o rete di management deve essere accessibile solo dagli amministratori autorizzati. La rete di monitoraggio deve essere riservata agli IDS/IPS e agli strumenti di controllo. La DMZ, infine, deve essere isolata dalla LAN e comunicare con essa solo tramite regole firewall esplicite.

WAN link	10.0.0.0/30	255.255.255.252	2	10.0.0.3	FW eth1 <-> Router
DMZ	10.0.1.0/29	255.255.255.248	6	10.0.1.7	Web Server + FW eth0
Piano 0 (LAN)	192.168.0.0/24	255.255.255.0	254	192.168.0.255	GW .254, NAS .100
Piano 1 (LAN)	192.168.1.0/24	255.255.255.0	254	192.168.1.255	GW .254
Piano 2 (LAN)	192.168.2.0/24	255.255.255.0	254	192.168.2.255	GW .254
Piano 3 (LAN)	192.168.3.0/24	255.255.255.0	254	192.168.3.255	GW .254
Piano 4 (LAN)	192.168.4.0/24	255.255.255.0	254	192.168.4.255	GW .254
Piano 5 (LAN)	192.168.5.0/24	255.255.255.0	254	192.168.5.255	GW .254
Monitoraggio	192.168.100.0/24	255.255.255.0	254	192.168.100.255	IDS/IPS 1,2,3
Supernet LAN	192.168.0.0/21	255.255.248.0	2046	192.168.7.255	Sommario route router

Figura 5 - Segmentazione logica per zone e subnet.

3.4. Piano di indirizzamento IP

Il piano di indirizzamento IP assegna a ogni zona una subnet dedicata, coerente con la segmentazione logica del progetto. L'obiettivo è evitare sovrapposizioni, rendere la rete leggibile e garantire spazio sufficiente per eventuali espansioni.

A differenza di una semplice rete unica, il piano IP utilizza più subnet con funzioni diverse: una rete punto-punto per il collegamento router/firewall, una subnet dedicata alla DMZ, subnet /24 per i piani dell'edificio, una rete dedicata al monitoraggio IDS/IPS e una supernet LAN per riepilogare l'indirizzamento interno.

Gli indirizzi gateway sono assegnati al router centrale, al core switch o alle interfacce firewall in base alla zona. Gli host client possono utilizzare DHCP, mentre dispositivi critici come firewall, router, core switch, NAS, web server e IDS/IPS devono avere indirizzi statici.

L'assegnazione statica proposta è la seguente:

- Internet/WAN: 203.0.113.1/30.
- Web Server DVWA: 10.0.1.2/29.
- Firewall esterno/DMZ: 10.0.1.1/29.
- Firewall interno/LAN: 10.0.0.1/30.
- Router WAN: 10.0.0.2/30.
- Core Switch management: 192.168.0.253/21.
- NAS: 192.168.0.100/24.
- IDS/IPS 1: 192.168.100.1/24.
- IDS/IPS 2: 192.168.100.2/24.
- IDS/IPS 3: 192.168.100.3/24.
- PC Piano 0: 192.168.0.2 - 192.168.0.21/24.
- PC Piano 1: 192.168.1.2 - 192.168.1.21/24.
- PC Piano 2: 192.168.2.2 - 192.168.2.21/24.
- PC Piano 3: 192.168.3.2 - 192.168.3.21/24.
- PC Piano 4: 192.168.4.2 - 192.168.4.21/24.
- PC Piano 5: 192.168.5.2 - 192.168.5.21/24.

Negli screenshot di laboratorio possono comparire indirizzi semplificati, come Kali Linux 192.168.10.101 e Metasploitable 192.168.20.101. Tali indirizzi sono stati utilizzati per la

simulazione pratica di firewall e DMZ e non sostituiscono il piano IP progettuale riportato sopra.

4.2 Assegnazione IP per dispositivo

Dispositivo	Interfaccia	Indirizzo IP	Mask
Internet / WAN	—	203.0.113.1	255.255.255.252
Web Server DVWA	eth0	10.0.1.2	255.255.255.248
Firewall (ext/DMZ)	eth0	10.0.1.1	255.255.255.248
Firewall (int/LAN)	eth1	10.0.0.1	255.255.255.252
Router (WAN)	eth0	10.0.0.2	255.255.255.252
Core Switch	mgmt	192.168.0.253	255.255.248.0
NAS	eth0	192.168.0.100	255.255.255.0
IDS/IPS 1	eth0	192.168.100.1	255.255.255.0
IDS/IPS 2	eth0	192.168.100.2	255.255.255.0
IDS/IPS 3	eth0	192.168.100.3	255.255.255.0
PC Piano 0 (range)	eth0	192.168.0.2-.21	255.255.255.0
PC Piano 1 (range)	eth0	192.168.1.2-.21	255.255.255.0
PC Piano 2 (range)	eth0	192.168.2.2-.21	255.255.255.0
PC Piano 3 (range)	eth0	192.168.3.2-.21	255.255.255.0
PC Piano 4 (range)	eth0	192.168.4.2-.21	255.255.255.0
PC Piano 5 (range)	eth0	192.168.5.2-.21	255.255.255.0

Figura 10 - Piano di indirizzamento IP e assegnazioni statiche.

3.5. Apparati di rete

L'infrastruttura di rete della Compagnia Theta è composta da apparati con funzioni specifiche, necessari per garantire connettività, segmentazione, sicurezza e monitoraggio.

Gli switch di piano rappresentano il primo livello di collegamento per le postazioni aziendali. Ogni piano dispone di uno switch dedicato, collegato alle 20 postazioni previste. Gli switch devono supportare VLAN o segmentazione equivalente e devono avere porte sufficienti per eventuali espansioni.

Il router centrale o core router gestisce l'instradamento tra le diverse reti. Attraverso routing inter-VLAN o routing tra subnet, permette la comunicazione tra segmenti solo quando autorizzata dalle policy definite.

Il firewall perimetrale è collocato tra Internet e la rete aziendale. Il suo compito è filtrare il traffico in ingresso e in uscita, consentendo solo i servizi necessari e bloccando accessi non autorizzati.

Il NAS è il sistema di archiviazione centralizzata. Deve essere accessibile solo dalla rete interna autorizzata e protetto tramite autenticazione, permessi granulari e backup periodici. Se non è stato configurato nella simulazione, viene considerato componente previsto nel modello progettuale.

Il web server è simulato tramite Metasploitable/DVWA e viene posizionato in DMZ. Questa collocazione riduce il rischio che una compromissione del servizio web possa propagarsi direttamente alla LAN.

I tre IDS/IPS sono previsti come sistemi di monitoraggio e prevenzione delle intrusioni. Possono rilevare scansioni, exploit, traffico anomalo o comunicazioni non previste. Se non sono presenti screenshot di configurazione, il loro posizionamento va inteso come progettuale.

Nel complesso, gli apparati scelti permettono di costruire un'infrastruttura ordinata, controllabile e coerente con i requisiti della traccia.

2. Struttura Fisica dell'Edificio

L'edificio oggetto dell'intervento e' strutturato su 6 piani (Piano 0 — Piano 5). Ciascun piano ospita 20 postazioni computer collegate a uno switch dedicato di livello access.

Piano	Postazioni	Switch	Subnet assegnata
Piano 0 (Terra)	20 PC + NAS	Switch-P0	192.168.0.0/24
Piano 1	20 PC	Switch-P1	192.168.1.0/24
Piano 2	20 PC	Switch-P2	192.168.2.0/24
Piano 3	20 PC	Switch-P3	192.168.3.0/24
Piano 4	20 PC	Switch-P4	192.168.4.0/24
Piano 5	20 PC	Switch-P5	192.168.5.0/24
TOTALE	**120 PC**	**6 Switch**	**192.168.0.0/21 (supernet)**

3. Componenti di Rete

3.1 Dispositivi principali

Componente	Quantita'	Ruolo	Posizione
Switch access	6	Collegamento 20 PC per piano	Ogni piano
Core Switch	1	Aggregazione switch di piano	Piano 0 / CED
Router centrale	1	Routing LAN <-> WAN	Piano 0 / CED
Firewall perimetrale	1	Separazione LAN, DMZ e Internet	Piano 0 / CED
Web Server (DVWA)	1	Server applicativo in DMZ	Zona DMZ
NAS	1	Storage condiviso aziendale	Piano 0 (SW-P0)
IDS/IPS	3	Monitoraggio e prevenzione intrusioni	Perimetro LAN

Figura 11 - Struttura fisica dell'edificio e componenti principali di rete.

3.6. Regole firewall iniziali

Le regole firewall iniziali sono state definite per controllare il traffico tra Internet, DMZ, LAN interna, NAS e rete di management. La configurazione segue il principio del minimo privilegio: ogni comunicazione viene consentita solo se necessaria, mentre tutto il traffico non previsto viene bloccato.

Nel modello progettuale finale, il web server risulta collocato nella DMZ indicata dal piano IP. Nella simulazione di laboratorio, invece, sono stati utilizzati indirizzi semplificati per verificare

il comportamento del firewall: Kali Linux è stata usata come macchina di test e Metasploitable/DVWA come web server.

Le regole principali sono:

• Regola 1 - LAN/Kali -> DMZ/Web Server (Pass): consente alla macchina di test autorizzata di raggiungere il web server in DMZ per verificare connettività, accesso HTTP e test Python.

• Regola 2 - Accesso HTTP al Web Server in DMZ (Pass): consente il traffico HTTP sulla porta 80 verso Metasploitable/DVWA. Se il test proviene dall'esterno, la regola va letta come WAN -> Web Server DMZ porta 80; se proviene da Kali, come LAN/Kali -> Web Server DMZ porta 80.

• Regola 3 - DMZ -> LAN (Block): impedisce al web server in DMZ di comunicare liberamente verso Kali e verso la rete interna. Questa regola è fondamentale per evitare movimento laterale in caso di compromissione del server web.

• Regola 4 - NAT Port Forward WAN -> Metasploitable: rende raggiungibile dall'esterno esclusivamente il servizio web di Metasploitable sulla porta autorizzata, senza esporre direttamente la LAN interna o altri servizi non necessari.

Il traffico da Internet verso la LAN interna deve essere bloccato completamente. Nessun host esterno deve poter raggiungere direttamente i computer aziendali, il NAS o gli apparati di rete.

Il traffico da LAN verso Internet può essere consentito per servizi necessari agli utenti, come navigazione web e DNS, preferibilmente con logging e policy aziendali.

Il traffico da DMZ verso LAN deve essere bloccato di default. Eventuali eccezioni devono essere motivate, documentate e limitate ai soli servizi indispensabili.

L'accesso amministrativo agli apparati deve essere consentito solo da host autorizzati, preferibilmente appartenenti alla rete di management, tramite protocolli sicuri come SSH o HTTPS.

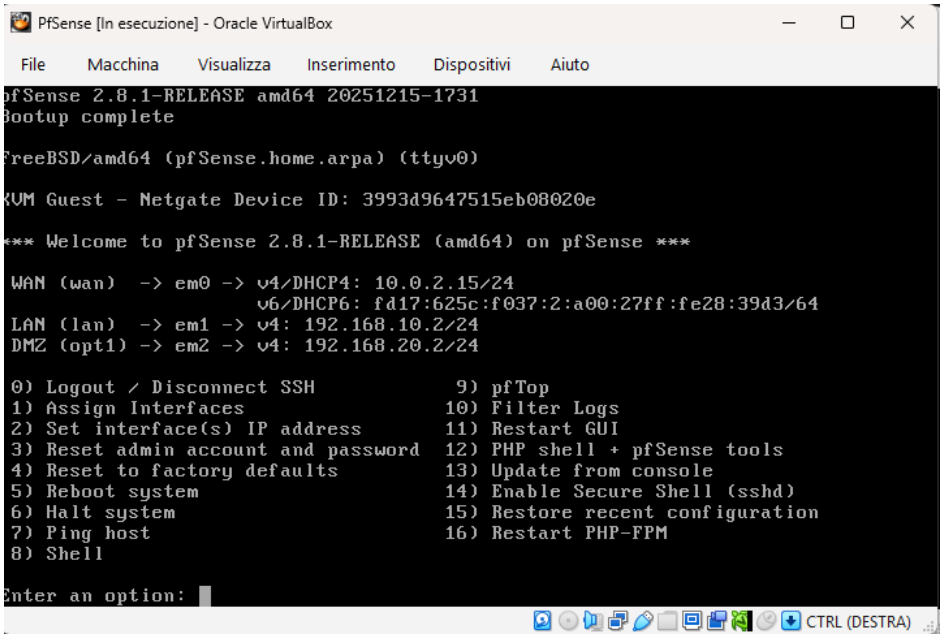

Figura 12 - Interfacce pfSense WAN, LAN e DMZ nella simulazione.

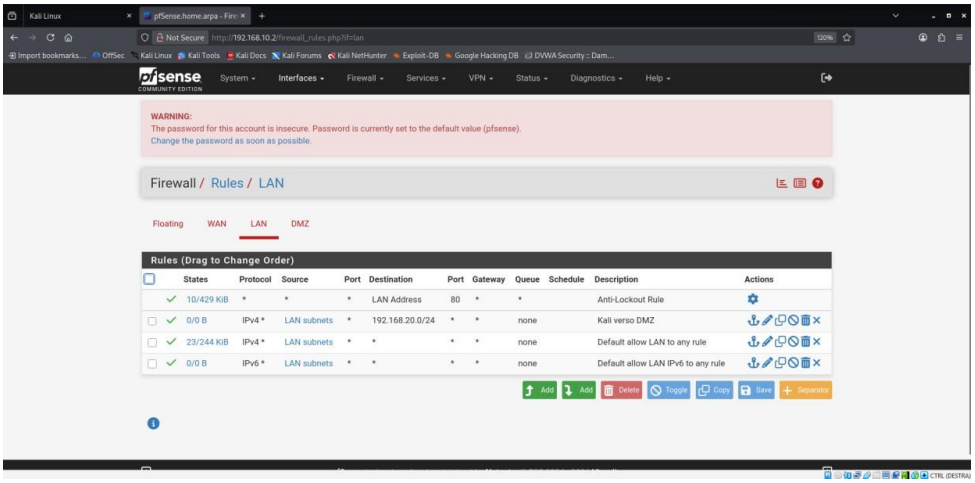

Figura 13 - Regola firewall LAN/Kali verso DMZ.

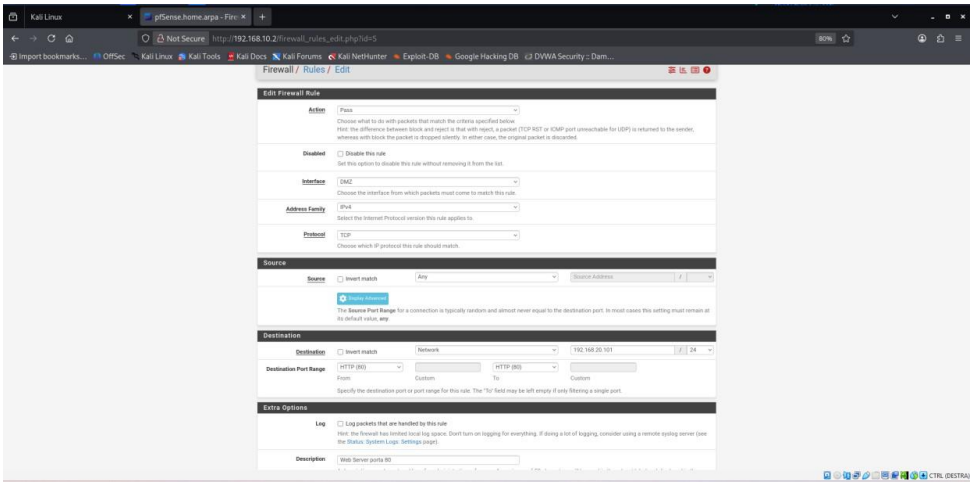

Figura 14 - Regola firewall per accesso HTTP al web server in DMZ.

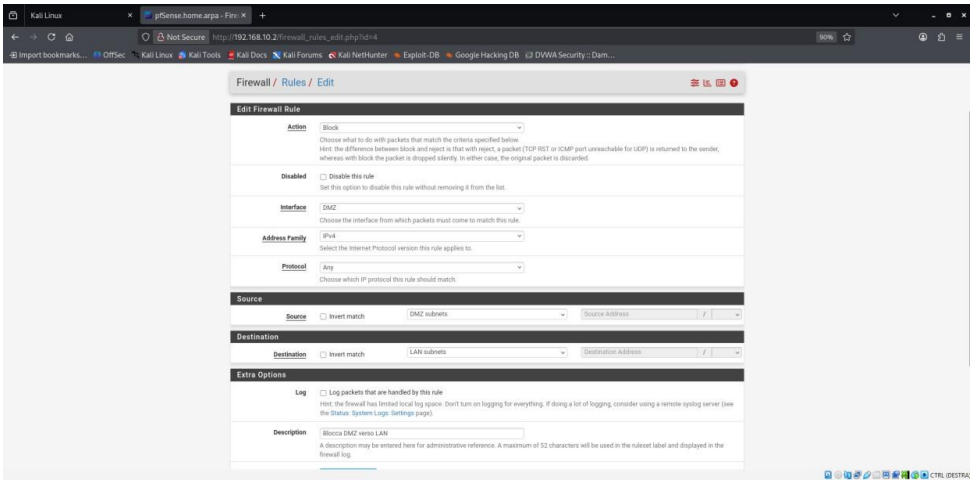

Figura 15 - Regola firewall di blocco DMZ verso LAN.

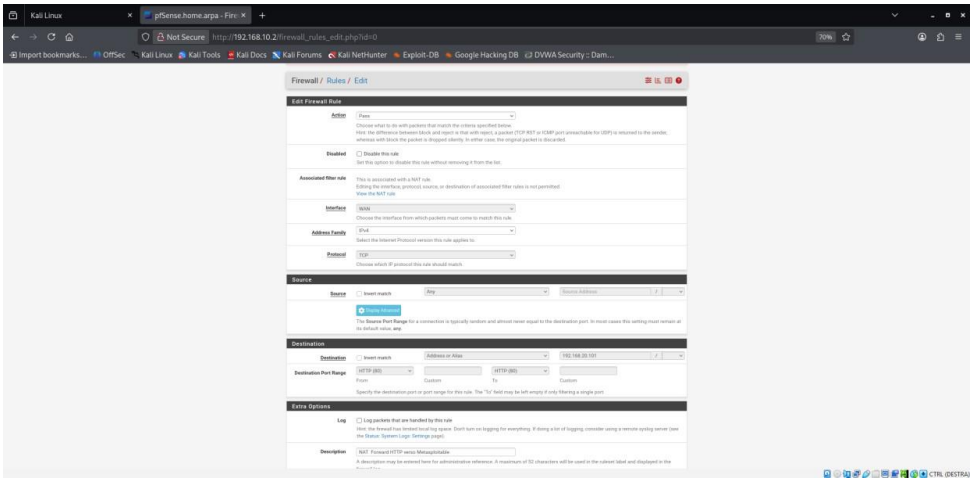

Figura 1c - NAT Port Forward WAN verso Metasploitable/DVWA.

3.7. Web server e DMZ

Il web server della Compagnia Theta viene simulato tramite macchina Metasploitable/DVWA. Questa scelta permette di lavorare in un ambiente controllato e adatto alla verifica di servizi web, metodi HTTP e configurazioni di sicurezza.

Il servizio web principale è raggiungibile tramite porta 80 HTTP. Nel progetto, l'accesso al server viene utilizzato per verificare la raggiungibilità del servizio, testare i metodi HTTP abilitati e controllare l'esposizione delle porte tramite lo scanner sviluppato in Python.

La DMZ crea una zona intermedia tra Internet e la LAN interna. Il suo scopo è ospitare servizi esposti verso l'esterno senza collocarli nella stessa rete dei client aziendali o del NAS.

Nel modello progettuale, il web server in DMZ può ricevere traffico HTTP/HTTPS dall'esterno, ma non deve avere accesso libero alla LAN interna. Nella simulazione pratica sono stati verificati almeno la connettività tra Kali e Metasploitable e il comportamento delle regole firewall associate.

I test previsti o documentabili per il web server e la DMZ sono:

- ping da Kali Linux verso Metasploitable/DVWA;
- accesso via browser all'indirizzo IP del web server;
- verifica della pagina web esposta, ad esempio homepage Metasploitable o DVWA;
- controllo dei servizi attivi tramite scansione porte;
- test dei metodi HTTP abilitati;

- verifica dell'isolamento tra DMZ e LAN;
- controllo delle regole firewall applicate.

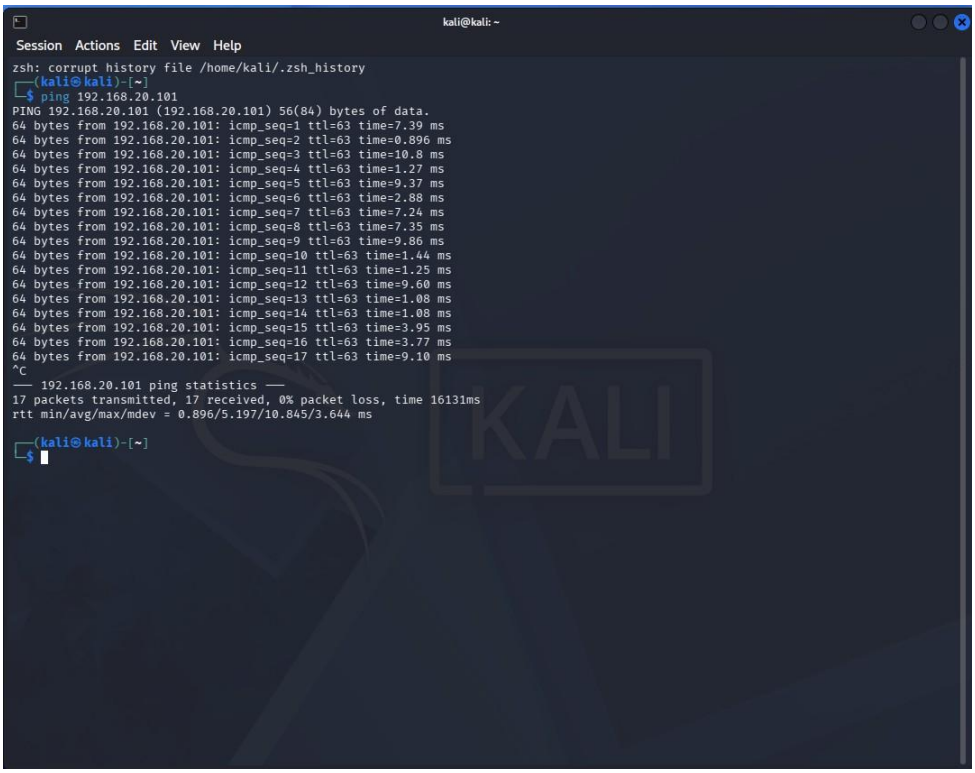

Figura 17 - Ping da Kali Linux verso Metasploitable/DVWA.

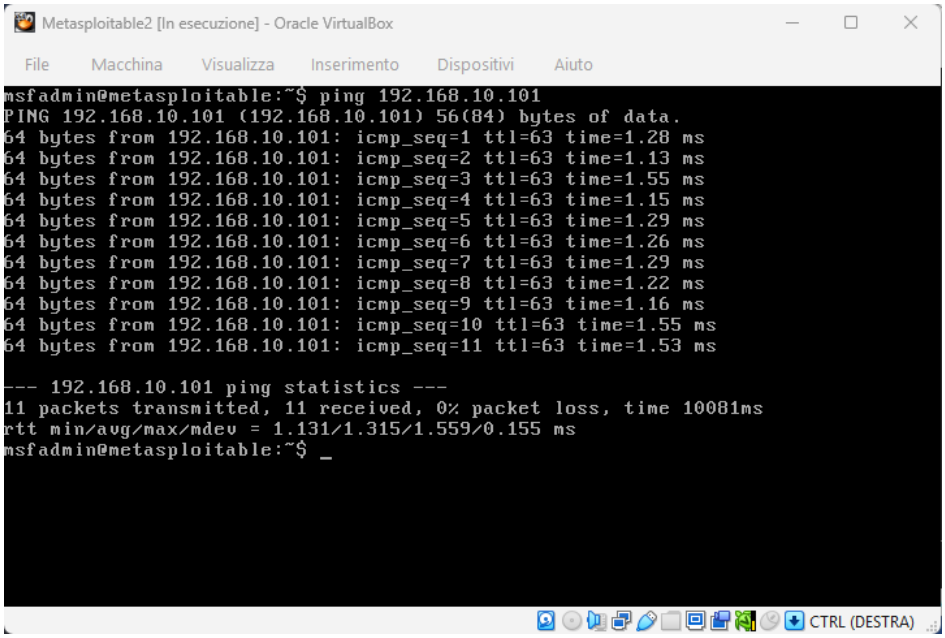

Figura 18 - Test preliminare di connettività prima dell'applicazione del blocco DMZ → LAN.

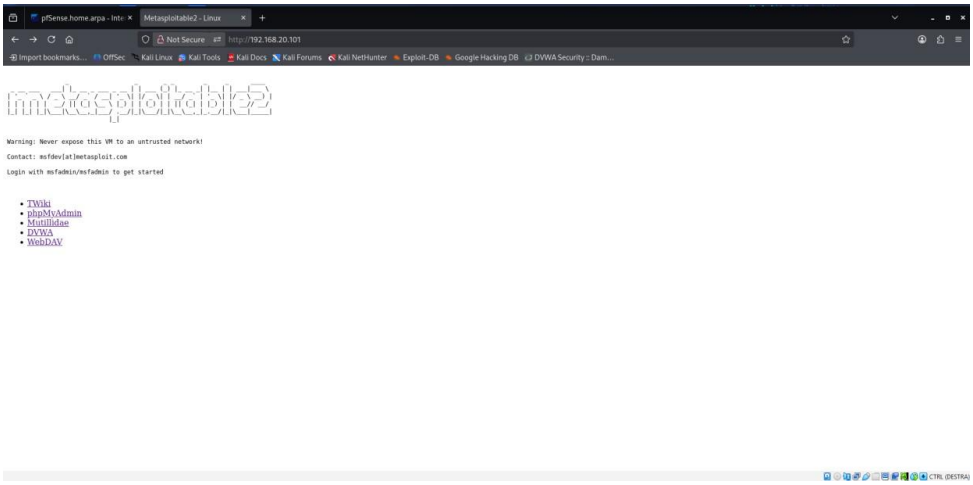

Figura 15 - Pagina principale Metasploitable/DVWA raggiungibile da browser.

3.8. HTTP Tester

NOTA: Gli screenshot degli strumenti Python sono stati eseguiti in un ambiente di test equivalente, con Metasploitable/DVWA raggiungibile all'indirizzo 192.168.30.2

Il modulo HTTP Tester è stato sviluppato con l'obiettivo di verificare il comportamento del web server rispetto a diversi metodi HTTP. Lo strumento è stato realizzato in Python e consente di inviare richieste controllate verso un URL specificato dall'utente, identificando quali operazioni il server accetta, rifiuta o gestisce con errore.

```
Users > lex > Desktop > HTTP Tester.py > ...
requests
Search (⇧⌘F)
3   HTTP_METHODS = [
4       "GET", "POST", "PUT", "DELETE", "PATCH", "OPTIONS", "HEAD", "TRACE"
5   ]
6
7   def check_methods(url):
8       results = []
9
10      for method in HTTP_METHODS:
11          try:
12              response = requests.request(
13                  method,
14                  url,
15                  timeout=5,
16                  allow_redirects=False
17              )
18
19              status = response.status_code
20
21              if status == 200:
22                  note = "OK (probabilmente supportato)"
23              elif status == 301 or status == 302:
24                  note = "Redirect (supportato)"
25              elif status == 401:
26                  note = "Richiede autenticazione"
27              elif status == 403:
28                  note = "Accesso vietato (ma metodo esiste)"
29              elif status == 405:
30                  note = "Non consentito"
31              elif status == 501:
32                  note = "Non implementato"
33              else:
34                  note = "Risposta ricevuta"
35
36              results.append((method, status, note))
37
38          except requests.RequestException:
39              results.append((method, "ERR", "Errore di connessione"))
40
41      return results
42
43  print()
44  print()
45
46  def main():
47      url = input("Inserisci l'URL da testare (es: http://www.google.com): ").strip()
48
49      if not url.startswith("http"):
50          print("Errore: URL non valido")
51          return
52
53      print(f"\nAnalisi dei metodi HTTP per: {url}\n")
54
55      results = check_methods(url)
56
57      enabled = []
58
59      for method, status, note in results:
60          print(f"{method:8} → {status} → {note}")
61
62          if status not in [405, 501, "ERR"]:
63              enabled.append(method)
64
65      print("\nMetodi probabilmente abilitati:")
66      print(", ".join(enabled) if enabled else "Nessuno")
67
68
69  if __name__ == "__main__":
70      main()
71
72  print()
73  print()
```

Figura 20 - Codice Python dello script HTTP Tester.

Il programma richiede in input un URL da analizzare e invia richieste HTTP utilizzando diversi metodi. Oltre ai metodi richiesti dalla traccia, lo script verifica anche metodi aggiuntivi per ottenere un controllo più completo:

- GET

- POST
- PUT
- DELETE
- PATCH
- HEAD
- OPTIONS
- TRACE

Per ogni metodo, il programma restituisce il relativo codice di stato HTTP. I codici di risposta permettono di interpretare il comportamento del server: i codici 2xx indicano una richiesta accettata o completata, i codici 4xx indicano un errore lato client e i codici 5xx indicano un errore lato server.

Lo script utilizza la libreria requests, imposta uno User-Agent e applica un timeout per evitare blocchi prolungati durante l'esecuzione. La versione dello script presente nello screenshot classifica i risultati in base agli status code e alle note associate; eventuali riferimenti all'header Allow devono essere mantenuti solo se l'output dello script lo mostra effettivamente.

Nel contesto del progetto, l'HTTP Tester è stato utilizzato o previsto per verificare il web server collocato in DMZ, simulato tramite Metasploitable/DVWA. L'obiettivo è comprendere quali tipologie di richieste il server è disposto ad accettare e individuare metodi non necessari da disabilitare.

Come raccomandazione, in un contesto aziendale devono rimanere abilitati solo i metodi indispensabili al funzionamento dell'applicazione, generalmente GET e POST. Metodi come PUT, DELETE, PATCH o TRACE devono essere disabilitati o limitati se non strettamente necessari.

```
● lex@Air-di-Alex ~ % /usr/local/bin/python3 "/Users/lex/Desktop/HTTP Tester.py"


  Inserisci l'URL da testare (es: http://www.google.com): http://192.168.30.2

  Analisi dei metodi HTTP per: http://192.168.30.2

  GET      → 200 → OK (probabilmente supportato)
  POST     → 200 → OK (probabilmente supportato)
  PUT      → 403 → Accesso vietato (ma metodo esiste)
  DELETE   → 403 → Accesso vietato (ma metodo esiste)
  PATCH    → 403 → Accesso vietato (ma metodo esiste)
  OPTIONS  → 403 → Accesso vietato (ma metodo esiste)
  HEAD     → 200 → OK (probabilmente supportato)
  TRACE    → 200 → OK (probabilmente supportato)

  Metodi probabilmente abilitati:
  GET, POST, PUT, DELETE, PATCH, OPTIONS, HEAD, TRACE
```

Figura 21 - Esecuzione HTTP Tester e status code dei metodi testati.

3.G. Scansione porte

Il modulo di scansione porte è stato sviluppato in Python con lo scopo di verificare quali porte risultano aperte o chiuse su un determinato dispositivo della rete. Lo strumento consente di analizzare un host, identificare i servizi potenzialmente attivi e raccogliere informazioni utili per la valutazione della sicurezza dell'infrastruttura.

Users > lex > Desktop > scan porte.py > ...

```python
import socket
from concurrent.futures import ThreadPoolExecutor

SERVIZI_COMUNI = {
    20: "FTP Data",
    21: "FTP",
    22: "SSH",
    23: "Telnet",
    25: "SMTP",
    53: "DNS",
    80: "HTTP",
    110: "POP3",
    139: "NetBIOS",
    143: "IMAP",
    443: "HTTPS",
    445: "SMB",
    3306: "MySQL",
    5432: "PostgreSQL",
    8080: "HTTP Proxy/Web"
}

def scansiona_porta(host, porta):
    sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    sock.settimeout(0.5)

    risultato = sock.connect_ex((host, porta))
    sock.close()

    if risultato == 0:
        servizio = SERVIZI_COMUNI.get(porta, "Servizio sconosciuto")
        return porta, "APERTA", servizio
    else:
        return porta, "chiusa", "-"

def main():
    host = input("Inserisci IP o hostname da scansionare: ")
    porta_iniziale = int(input("Porta iniziale: "))
    porta_finale = int(input("Porta finale: "))

    print(f"\nScansione di {host} dalla porta {porta_iniziale} alla porta {porta_finale}...\n")

    porte = range(porta_iniziale, porta_finale + 1)
    risultati = []

    with ThreadPoolExecutor(max_workers=50) as executor:
        risultati = list(executor.map(lambda porta: scansiona_porta(host, porta), porte))

    porte_aperte = [r for r in risultati if r[1] == "APERTA"]

    print("RISULTATI SCANSIONE")
    print("-" * 50)

    if porte_aperte:
        for porta, stato, servizio in porte_aperte:
            print(f"Porta {porta}: {stato} - {servizio}")
    else:
        print("Nessuna porta aperta trovata.")

    with open("risultati_scansione.txt", "w") as file:
        file.write(f"Risultati scansione per {host}\n")
        file.write("-" * 50 + "\n")

        for porta, stato, servizio in risultati:
            file.write(f"Porta {porta}: {stato} - {servizio}\n")

    print("\nRisultati salvati nel file: risultati_scansione.txt")

if __name__ == "__main__":
    main()
```

Figura 22 - Codice Python dello scanner porte.

Il programma richiede in input l'indirizzo IP o hostname del dispositivo da analizzare, la porta iniziale e la porta finale dell'intervallo da controllare. Successivamente tenta una connessione TCP verso ciascuna porta compresa nel range indicato.

Se la connessione viene stabilita correttamente, la porta viene considerata aperta; in caso contrario viene classificata come chiusa. Per migliorare le prestazioni, lo script utilizza ThreadPoolExecutor ed esegue più controlli in parallelo.

Lo script contiene una tabella interna che associa alcune porte comuni ai relativi servizi, ad esempio 21/FTP, 22/SSH, 25/SMTP, 53/DNS, 80/HTTP, 443/HTTPS, 445/SMB, 3306/MySQL, 5432/PostgreSQL e 8080/HTTP Proxy-Web.

Al termine della scansione, il programma mostra a schermo le porte aperte individuate e salva un report nel file risultati_scansione.txt. Questo file è importante perché costituisce un'evidenza documentale da allegare o citare nella reportistica finale.

Nel contesto del progetto, la scansione porte consente di verificare l'esposizione dei servizi sul web server in DMZ e sugli apparati analizzati. Una porta aperta non rappresenta automaticamente una vulnerabilità, ma indica la presenza di un servizio raggiungibile che deve essere giustificato, aggiornato e protetto.

Come raccomandazione, le porte non necessarie devono essere chiuse o filtrate tramite firewall, mentre quelle indispensabili devono essere limitate ai soli segmenti autorizzati.

```
lex@Air-di-Alex ~ % /usr/local/bin/python3 "/Users/lex/Desktop/scan porte.py"
Inserisci IP o hostname da scansionare: 192.168.30.2
Porta iniziale: 1
Porta finale: 1000

Scansione di 192.168.30.2 dalla porta 1 alla porta 1000...

RISULTATI SCANSIONE
------------------------------------------------
Porta 21: APERTA - FTP
Porta 22: APERTA - SSH
Porta 23: APERTA - Telnet
Porta 25: APERTA - SMTP
Porta 53: APERTA - DNS
Porta 80: APERTA - HTTP
Porta 111: APERTA - Servizio sconosciuto
Porta 139: APERTA - NetBIOS
Porta 445: APERTA - SMB
Porta 512: APERTA - Servizio sconosciuto
Porta 513: APERTA - Servizio sconosciuto
Porta 514: APERTA - Servizio sconosciuto

Risultati salvati nel file: risultati_scansione.txt
lex@Air-di-Alex ~ %
```

Figura 23 - Esecuzione dello scanner porte su Metasploitable/DVWA.

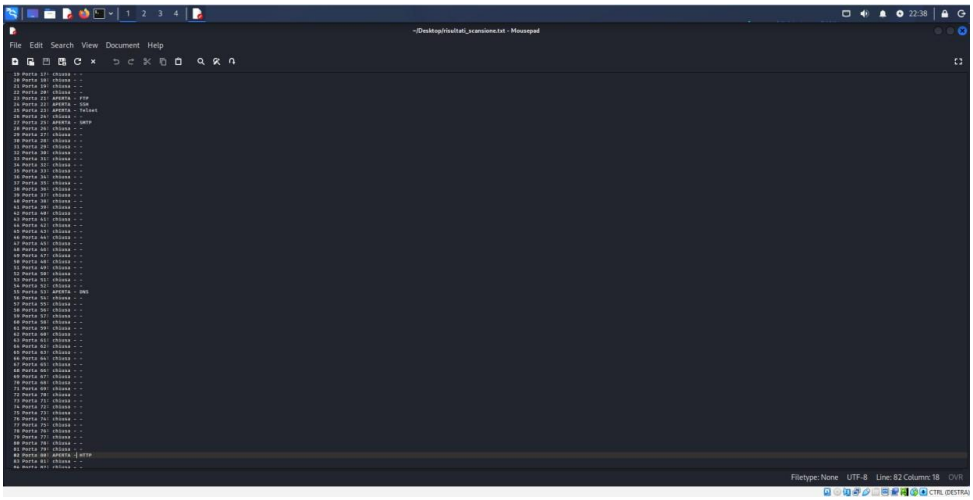

Figura 24 - File risultati_scansione.txt con porte aperte e chiuse.

3.10. Sniffer di rete

Il modulo Sniffer di rete è stato sviluppato come strumento bonus di monitoraggio del traffico, in linea con la richiesta opzionale della traccia relativa alla cattura dei socket di rete. A differenza dello scanner porte, che verifica quali porte risultano aperte su un host, lo sniffer osserva i pacchetti in transito sulla macchina su cui viene eseguito.

Users > lex > Desktop > Sniffer.py > ...

```python
import socket
import struct

def get_service(port):
    services = {
        80: "HTTP",
        443: "HTTPS",
        22: "SSH",
        53: "DNS",
        25: "SMTP",
        110: "POP3",
        143: "IMAP",
        3306: "MySQL",
        5432: "PostgreSQL",
    }
    return services.get(port, "ALTRO")

def main():
    # Cattura pacchetti Ethernet su Linux
    sniffer = socket.socket(socket.AF_PACKET, socket.SOCK_RAW, socket.ntohs(3))

    print("Sniffer avviato. Genera traffico con: curl http://example.com")
    print("Premi Ctrl+C per uscire.\n")

    try:
        while True:
            packet, _ = sniffer.recvfrom(65535)

            # Header Ethernet = primi 14 byte
            eth_header = packet[:14]
            eth = struct.unpack("!6s6sH", eth_header)
            eth_protocol = socket.ntohs(eth[2])

            # IPv4 = 0x0800
            if eth_protocol != 8:
                continue

            # Header IP
            ip_header = packet[14:34]
            iph = struct.unpack("!BBHHHBBH4s4s", ip_header)

            ihl = (iph[0] & 0xF) * 4
            protocol = iph[6]
            src_ip = socket.inet_ntoa(iph[8])
            dst_ip = socket.inet_ntoa(iph[9])

            # TCP = 6
            if protocol == 6:
                tcp_start = 14 + ihl
                tcp_header = packet[tcp_start:tcp_start + 20]

                if len(tcp_header) < 20:
                    continue

                tcph = struct.unpack("!HHLLBBHHH", tcp_header)
                src_port = tcph[0]
                dst_port = tcph[1]

                print(
                    f"TCP | {src_ip}:{src_port} -> {dst_ip}:{dst_port} "
                    f"| {get_service(dst_port)}"
                )

            # UDP = 17
            elif protocol == 17:
                udp_start = 14 + ihl
                udp_header = packet[udp_start:udp_start + 8]

                if len(udp_header) < 8:
                    continue

                udph = struct.unpack("!HHHH", udp_header)
                src_port = udph[0]
                dst_port = udph[1]

                print(
                    f"UDP | {src_ip}:{src_port} -> {dst_ip}:{dst_port} "
                    f"| {get_service(dst_port)}"
                )

    except KeyboardInterrupt:
        print("\nSniffer fermato.")

if __name__ == "__main__":
    main()
```

Figura 25 - Codice Python dello sniffer di rete.

Lo script è stato realizzato in Python utilizzando i moduli socket e struct. Il programma crea un socket raw che consente di intercettare pacchetti di rete a basso livello. Una volta avviato, resta in ascolto e mostra le comunicazioni rilevate senza modificarle e senza interferire con il traffico.

Il programma analizza principalmente traffico IPv4 e distingue tra protocolli TCP e UDP. Per ogni pacchetto intercettato estrae indirizzo IP sorgente, porta sorgente, indirizzo IP di destinazione, porta di destinazione, protocollo e servizio più probabile associato alla porta.

All’interno dello script è presente una tabella di associazione tra porte comuni e servizi noti, come HTTP, HTTPS, SSH, DNS, SMTP, IMAP, MySQL e PostgreSQL. Se la porta non è presente nella tabella, il servizio viene indicato come ALTRO.

Nel contesto del progetto, lo sniffer può supportare la verifica del traffico generato dai test HTTP e dalla scansione porte, oltre ad aiutare nell’analisi preliminare di traffico anomalo. Il suo utilizzo deve avvenire esclusivamente in ambiente autorizzato e di laboratorio.

Lo sniffer non sostituisce strumenti professionali come IDS/IPS, firewall logging o SIEM, ma rappresenta un supporto didattico e operativo per comprendere il comportamento della rete durante i test.

Durante la simulazione è stato acquisito anche l’output dello sniffer. Lo screenshot mostra traffico DNS e HTTPS intercettato dalla macchina Kali, con indirizzi IP sorgente/destinazione, porte e protocollo rilevato. Questa evidenza dimostra il corretto funzionamento dello script di cattura dei pacchetti in ambiente autorizzato.

```
┌──(kali㉿kali)-[~]
└─$ sudo python3 Sniffer.py
Inserisci IP da filtrare (lascia vuoto per tutto):

Sniffer avviato ...
Premi Ctrl+C per uscire.

UDP | 192.168.64.2:33019 → 192.168.64.1:53 | DNS
UDP | 192.168.64.2:33019 → 192.168.64.1:53 | DNS
UDP | 192.168.64.1:53 → 192.168.64.2:33019 | ALTRO
UDP | 192.168.64.1:53 → 192.168.64.2:33019 | ALTRO
TCP | 192.168.64.2:39126 → 146.75.53.91:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39126 | ALTRO
TCP | 192.168.64.2:39126 → 146.75.53.91:443 | HTTPS
TCP | 192.168.64.2:39126 → 146.75.53.91:443 | HTTPS
UDP | 192.168.64.2:56541 → 192.168.64.1:53 | DNS
UDP | 192.168.64.2:56541 → 192.168.64.1:53 | DNS
UDP | 192.168.64.1:53 → 192.168.64.2:56541 | ALTRO
UDP | 192.168.64.1:53 → 192.168.64.2:56541 | ALTRO
TCP | 192.168.64.2:35498 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35498 | ALTRO
TCP | 192.168.64.2:35498 → 34.160.144.191:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39126 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:39126 → 146.75.53.91:443 | HTTPS
UDP | 192.168.64.2:48794 → 192.168.64.1:53 | DNS
UDP | 192.168.64.2:48794 → 192.168.64.1:53 | DNS
UDP | 192.168.64.1:53 → 192.168.64.2:48794 | ALTRO
UDP | 192.168.64.1:53 → 192.168.64.2:48794 | ALTRO
TCP | 192.168.64.2:39140 → 146.75.53.91:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39140 | ALTRO
TCP | 192.168.64.2:39140 → 146.75.53.91:443 | HTTPS
TCP | 192.168.64.2:39140 → 146.75.53.91:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39140 | ALTRO
TCP | 192.168.64.2:39140 → 146.75.53.91:443 | HTTPS
UDP | 192.168.64.2:41888 → 192.168.64.1:53 | DNS
UDP | 192.168.64.2:41888 → 192.168.64.1:53 | DNS
UDP | 192.168.64.1:53 → 192.168.64.2:41888 | ALTRO
UDP | 192.168.64.1:53 → 192.168.64.2:41888 | ALTRO
TCP | 192.168.64.2:39148 → 146.75.53.91:443 | HTTPS
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39148 | ALTRO
TCP | 192.168.64.2:39148 → 146.75.53.91:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 192.168.64.2:39126 → 146.75.53.91:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35524 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 192.168.64.2:35524 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
TCP | 34.160.144.191:443 → 192.168.64.2:35510 | ALTRO
TCP | 192.168.64.2:35510 → 34.160.144.191:443 | HTTPS
UDP | 192.168.64.2:42199 → 192.168.64.1:53 | DNS
UDP | 192.168.64.2:42199 → 192.168.64.1:53 | DNS
UDP | 192.168.64.1:53 → 192.168.64.2:42199 | ALTRO
UDP | 192.168.64.1:53 → 192.168.64.2:42199 | ALTRO
TCP | 192.168.64.2:36018 → 34.107.243.93:443 | HTTPS
TCP | 192.168.64.2:39164 → 146.75.53.91:443 | HTTPS
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 192.168.64.2:36018 → 34.107.243.93:443 | HTTPS
TCP | 192.168.64.2:36018 → 34.107.243.93:443 | HTTPS
TCP | 146.75.53.91:443 → 192.168.64.2:39164 | ALTRO
TCP | 192.168.64.2:39164 → 146.75.53.91:443 | HTTPS
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 34.107.243.93:443 → 192.168.64.2:36018 | ALTRO
TCP | 192.168.64.2:36018 → 34.107.243.93:443 | HTTPS
```

Figura 26 - Output dello sniffer di rete con traffico DNS e HTTPS catturato su Kali Linux.

3.11. Sicurezza e Hardening (misure previste e raccomandate)

La sezione descrive le misure previste e raccomandate per ridurre la superficie di attacco dell'infrastruttura e migliorare la protezione complessiva della rete. Dove non sono presenti screenshot di configurazione, tali misure devono essere considerate raccomandazioni progettuali per una futura implementazione completa.

La prima misura raccomandata riguarda la disabilitazione dei servizi inutilizzati. Ogni apparato o server deve mantenere attivi solo i servizi necessari al proprio funzionamento. Servizi non utilizzati, porte aperte senza motivo o protocolli obsoleti possono diventare punti di ingresso per un attaccante.

Le password di default devono essere sostituite e gli apparati devono utilizzare credenziali robuste. Router, switch, firewall, NAS e server devono essere accessibili solo dal personale autorizzato.

L'accesso amministrativo deve essere limitato alla rete di management e deve utilizzare protocolli sicuri come SSH o HTTPS. Protocolli non sicuri come Telnet devono essere disabilitati.

È raccomandato il logging centralizzato degli eventi generati da firewall, router, server e IDS/IPS. I log permettono di analizzare tentativi di accesso, traffico bloccato e possibili anomalie.

La separazione tra utenti, server, DMZ, management e security monitoring rappresenta una misura strutturale di sicurezza. Ogni area deve comunicare con le altre solo quando necessario e tramite regole documentate.

Il NAS deve essere protetto tramite permessi granulari, autenticazione e backup periodici. La DMZ non deve poter accedere direttamente al NAS.

Il principio del minimo privilegio deve essere applicato a utenti, servizi e apparati. Ogni soggetto deve disporre solo dei permessi necessari allo svolgimento della propria funzione.

Gli IDS/IPS devono essere monitorati periodicamente. In assenza di screenshot di alert o dashboard, il loro monitoraggio va indicato come misura prevista nel modello progettuale.

Misure principali previste o raccomandate:

- disabilitazione dei servizi inutilizzati;
- sostituzione delle password di default;
- utilizzo di password robuste;
- limitazione degli accessi amministrativi alla rete di management;
- uso di SSH/HTTPS per l'amministrazione;

• logging centralizzato;

• separazione tra utenti, server, DMZ, management e monitoraggio;

• aggiornamenti periodici;

• backup e permessi granulari sul NAS;

• documentazione delle regole firewall;

• monitoraggio degli eventi IDS/IPS.

6. Piano di Cablaggio e Sicurezza

6.1 Standard di cablaggio

- Cablaggio strutturato Cat 6A per tutti i link orizzontali (PC — Switch di piano).
- Fibra ottica multimodo OM4 per i link verticali (Switch di piano — Core Switch).
- Link Core Switch — Router e Router — Firewall: fibra single mode OS2.
- Rack 19" dedicato per piano con patch panel 48 porte.

6.2 Misure di sicurezza adottate

Misura	Descrizione	Dispositivo
Segmentazione VLAN	Una VLAN per piano, traffico isolato	Core Switch
Firewall perimetrale	ACL ingresso/uscita, NAT, stateful inspection	Firewall
DMZ	Web server isolato dalla LAN	Firewall + DMZ
IDS/IPS x3	Monitoraggio traffico, blocco intrusioni	IDS/IPS 1-3
Port Security	Limitazione MAC per porta switch	Switch di piano
NAS ACL	Accesso al NAS solo da subnet LAN interne	Router / FW

Figura 27 - Misure di sicurezza previste nel modello progettuale.

3.12. Piano di test: test eseguiti e test raccomandati

Il piano di test ha l'obiettivo di verificare che l'infrastruttura progettata rispetti i requisiti tecnici e di sicurezza. Per evitare incongruenze tra testo e screenshot, i test vengono distinti tra test eseguiti/documentabili nella simulazione e test raccomandati per l'implementazione completa.

Test eseguiti o documentabili nella simulazione:

• ping da Kali Linux verso Metasploitable/DVWA;

• verifica della comunicazione tra macchina di test e web server in DMZ;

• configurazione e verifica delle regole firewall pfSense principali;

• regola di blocco DMZ -> LAN;

• NAT/port forwarding verso il servizio web di Metasploitable;

Users > lex > Desktop > HTTP Tester.py > ...

Search (⇧⌘F)

```python
requests

HTTP_METHODS = [
    "GET", "POST", "PUT", "DELETE", "PATCH", "OPTIONS", "HEAD", "TRACE"
]

def check_methods(url):
    results = []

    for method in HTTP_METHODS:
        try:
            response = requests.request(
                method,
                url,
                timeout=5,
                allow_redirects=False
            )

            status = response.status_code

            if status == 200:
                note = "OK (probabilmente supportato)"
            elif status == 301 or status == 302:
                note = "Redirect (supportato)"
            elif status == 401:
                note = "Richiede autenticazione"
            elif status == 403:
                note = "Accesso vietato (ma metodo esiste)"
            elif status == 405:
                note = "Non consentito"
            elif status == 501:
                note = "Non implementato"
            else:
                note = "Risposta ricevuta"

            results.append((method, status, note))

        except requests.RequestException:
            results.append((method, "ERR", "Errore di connessione"))

    return results

print()
print()

def main():
    url = input("Inserisci l'URL da testare (es: http://www.google.com): ").strip()

    if not url.startswith("http"):
        print("Errore: URL non valido")
        return

    print(f"\nAnalisi dei metodi HTTP per: {url}\n")

    results = check_methods(url)

    enabled = []

    for method, status, note in results:
        print(f"{method:8} → {status} → {note}")

        if status not in [405, 501, "ERR"]:
            enabled.append(method)

    print("\nMetodi probabilmente abilitati:")
    print(", ".join(enabled) if enabled else "Nessuno")


if __name__ == "__main__":
    main()

print()
print()
```

Figura 28 - Codice Python dello script HTTP Tester.

- verifica del codice dello scanner porte;
- verifica del codice dello sniffer di rete.

Test documentati tramite screenshot inseriti nel report:

- accesso via browser alla pagina Metasploitable/DVWA;
- esecuzione dell'HTTP Tester con status code dei metodi testati;
- esecuzione dello scanner porte con elenco delle porte aperte/chiuse;

• visualizzazione del file risultati_scansione.txt;

• esecuzione dello sniffer con pacchetti TCP/UDP catturati, documentata nella sezione 3.10.

Test raccomandati per l'implementazione completa:

• ping tra host della stessa VLAN o subnet;

• ping tra VLAN/subnet autorizzate;

• verifica dell'accesso a Internet dai client;

• verifica dell'accesso al NAS solo da segmenti autorizzati;

• blocco dell'accesso al NAS da DMZ o segmenti non autorizzati;

• verifica degli alert IDS/IPS;

• controllo dei log firewall;

• verifica di backup e permessi NAS;

• test di isolamento completo tra DMZ, LAN, management e rete di monitoraggio.

Test documentali:

• verifica della completezza dello schema logico;

• verifica dello schema fisico o della topologia;

• controllo del piano IP;

• controllo della tabella di segmentazione;

• verifica dell'inventario apparati;

• verifica degli screenshot degli script Python;

• controllo della coerenza tra parte management e parte tecnica.

Il progetto risulta quindi validato per le componenti simulate e documentate, mentre le componenti non completamente simulate vengono trattate come raccomandazioni progettuali necessarie per una futura implementazione completa.

3.13. Criteri di accettazione

Il progetto può essere considerato accettabile se risponde ai requisiti funzionali, tecnici e di sicurezza definiti nella traccia e se le parti simulate sono supportate da evidenze documentali. I criteri di accettazione servono a verificare che la rete non sia soltanto descritta a livello teorico, ma anche validata attraverso test, screenshot e documentazione.

Il primo criterio riguarda la copertura delle postazioni: l'infrastruttura deve supportare 120 computer distribuiti su 6 piani, con uno switch dedicato per ciascun piano.

Il secondo criterio riguarda la separazione delle aree: rete interna, DMZ, NAS, management e monitoraggio devono essere trattati come segmenti distinti. Il web server deve essere collocato in DMZ e non deve avere accesso libero alla LAN.

Il terzo criterio riguarda il firewall: le regole devono impedire accessi diretti da Internet alla LAN, consentire solo i servizi necessari verso il web server e bloccare il traffico non autorizzato dalla DMZ verso la rete interna.

Il quarto criterio riguarda i test tecnici: HTTP Tester, scanner porte e sniffer devono essere documentati tramite codice e, quando possibile, tramite screenshot di esecuzione e output.

Il quinto criterio riguarda NAS e IDS/IPS: se non sono stati simulati completamente, devono essere presenti nel modello progettuale e indicati come componenti da implementare o completare in una fase successiva.

I criteri di accettazione sono quindi:

• presenza di una progettazione per 6 piani e 120 postazioni;

• presenza di switch di piano e apparato centrale di routing;

• presenza di firewall perimetrale e DMZ;

• web server Metasploitable/DVWA posizionato in DMZ;

• blocco del traffico non autorizzato tra DMZ e LAN;

• NAS previsto come storage centralizzato protetto;

• tre IDS/IPS previsti per il monitoraggio;

• strumenti Python per test HTTP, scansione porte e sniffer documentati;

• risultati di test e screenshot disponibili per le componenti simulate;

• raccomandazioni chiare per le componenti non simulate;

• report finale coerente tra parte management e parte tecnica.

Alla luce di questi criteri, il progetto può essere considerato conforme agli obiettivi iniziali se vengono inserite le evidenze mancanti indicate nel report e se la distinzione tra modello progettuale e simulazione pratica rimane chiara.

Nota metodologica finale: per mantenere rigore documentale, nel report sono state incluse come evidenze solo immagini e risultati effettivamente disponibili. Le componenti non integralmente documentate vengono trattate come parti previste del modello progettuale o come attività raccomandate per una futura implementazione completa.